Aplicación para gestionar turnos de atención del IESS

Analice una solicitud del cliente y conviértala en una propuesta de software sustentada en investigación, análisis de riesgos y criterio técnico.

Escenario ficticio con requisitos sobredimensionados de forma intencional. No describe sistemas reales. Deberá justificar qué requisitos conserva, modifica o elimina.

Escenario y solicitud del cliente

Para este ejercicio, una unidad de atención del IESS solicita una aplicación web y móvil para consultar disponibilidad, reservar citas, cancelar turnos y notificar cambios.

“Queremos disminuir las filas y las llamadas. El afiliado debe encontrar una cita y sus familiares deben poder ayudarlo. También queremos recopilar información médica desde el registro para que cualquier funcionario pueda orientarlo sin transferir la consulta a otra área.”

El escenario contempla 50.000 cuentas, 3.000 usuarios simultáneos y 120 funcionarios distribuidos entre atención al usuario, personal médico, administración y soporte.

Requisitos solicitados

ID	Categoría	Requisito solicitado por el cliente
I01	Funciones	Buscar turnos por especialidad, establecimiento y fecha; reservar, cancelar y reprogramar citas.
I02	Identificación	Solicitar nombres, cédula, fecha de nacimiento, correo y teléfono.
I03	Información laboral	Exigir empleador, cargo, sueldo, cuenta bancaria y copia del contrato de trabajo para reservar cualquier turno.
I04	Salud	Solicitar diagnósticos, antecedentes, medicamentos, alergias y resultados de laboratorio antes de mostrar disponibilidad.
I05	Datos adicionales	Preguntar religión, afiliación política y composición familiar para personalizar la atención.
I06	Familiares	Permitir que una persona gestione citas de otra ingresando únicamente su número de cédula y fecha de nacimiento.
I07	Autenticación	Utilizar cédula y una contraseña inicial formada por la fecha de nacimiento; dejar el cambio como opcional.
I08	Permisos	Permitir que recepción, médicos, administradores y soporte visualicen todos los expedientes y turnos.

ID	Categoría	Requisito solicitado por el cliente
I09	Notificaciones	Enviar por SMS y correo la especialidad, el diagnóstico registrado y un enlace directo para abrir la información sin iniciar sesión.
I10	Integración	Conectar la aplicación con un servicio de validación de afiliación y con el sistema de disponibilidad de citas.
I11	Auditoría	Registrar consultas y modificaciones incluyendo contraseñas, tokens y contenido completo de las solicitudes para facilitar el soporte.
I12	Infraestructura	Utilizar una computadora de oficina con 8 GB de RAM como servidor de aplicación y base de datos.
I13	Disponibilidad	Ofrecer atención continua, pero realizar mantenimiento diario de dos horas sin permitir reservas durante ese período.
I14	Conservación y análisis	Conservar todos los datos indefinidamente y entregarlos a un proveedor externo para entrenar un asistente de inteligencia artificial.

Actividad solicitada

Actúe como equipo consultor encargado del diseño seguro. Revise la pertinencia de los datos y las diferencias entre gestionar un turno y gestionar información clínica. Proponga cómo deberían funcionar la representación de familiares, los permisos, las integraciones y las notificaciones. Desarrolle los entregables indicados en las instrucciones siguientes.

Instrucciones y entregables

1 Depuración de requisitos

Analice cada requisito de la tabla y decida si debe conservarse, modificarse o eliminarse. Justifique su decisión y escriba el requisito definitivo. Cuando falte información, formule una pregunta concreta al cliente y declare cualquier supuesto utilizado.

2 Análisis de datos

Identifique los datos solicitados, su finalidad, clasificación, necesidad, personas que podrían acceder y plazo de conservación propuesto. Investigue la normativa ecuatoriana vigente y cite las disposiciones que respalden su análisis. No considere que todos los datos son necesarios únicamente porque el cliente los solicita.

3 Diseño propuesto

Presente los roles y permisos, componentes principales, integraciones y recorrido de los datos. Justifique la capacidad requerida considerando usuarios simultáneos, operaciones, almacenamiento y disponibilidad. Identifique las mediciones que necesitaría para validar ese dimensionamiento.

4 Matriz de riesgos

Utilice tantas filas como riesgos pertinentes identifique. Incluya los siguientes campos: ID y requisito relacionado; activo o dato; amenaza; vulnerabilidad o condición que la permitiría; escenario y consecuencia; propiedad afectada; probabilidad y justificación; impacto y justificación; nivel y prioridad; controles propuestos; verificación del control; riesgo residual estimado. Defina la escala de valoración y el procedimiento para determinar el nivel de riesgo. Diferencie amenaza, vulnerabilidad y consecuencia. Justifique el riesgo residual bajo el supuesto de que los controles se implementen y funcionen.

5 Relación con MITRE ATT&CK

Para los escenarios de ataque identificados, investigue las técnicas y subtécnicas pertinentes. Registre identificador, nombre, táctica asociada, relación con el escenario y controles que ayudarían a prevenirlo, detectarlo o responder. Seleccione las que correspondan al análisis; no limite el trabajo a una sola ni fuerce una correspondencia para cada riesgo. Distinga las técnicas del adversario de los controles defensivos.

6 Evidencias y fuentes

Explique cómo comprobaría la eficacia de los controles mediante pruebas y resultados esperados. Cite fuentes oficiales para normativa ecuatoriana y documentación técnica primaria para sustentar sus decisiones, incluyendo fecha de consulta.

Producto final

Propuesta de requisitos corregidos, análisis de datos, diseño general, matriz de riesgos, relación con MITRE ATT&CK y plan de verificación. Cierre con una explicación dirigida al cliente sobre los principales cambios y sus razones.